



**ZAP** by  
Checkmarx

# Latihan\_Laporan\_1

Laporan ini ditulis dan disusun oleh

- Habib Muzakki (Habib)
- Alumni Kelas 12 Agama (jurusan Agama)
- Alumni MAN 2 KOTA SERANG
- Mahasiswa D4 Vokasi Teknik Informatika (Harkat Negeri Tegal)
- Si pemula Cyber Security dan Bug Hunter (Bug Bounty)

**Sites:** <https://cdn.jsdelivr.net> <https://cdnjs.cloudflare.com> <https://www.google.com> <https://accounts.google.com> <https://juice-shop.github.io>

Generated on Sab, 18 Jul 2026 08:15:56

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

## Summary of Alerts

| Tingkat Risiko   | Number of Alerts |
|------------------|------------------|
| Tinggi           | 0                |
| Sedang           | 4                |
| Lemah            | 3                |
| Informasi        | 3                |
| False Positives: | 0                |

## Insights

| Level | Alasan        | Site                                                                    | Deskripsi                                              | Statistic |
|-------|---------------|-------------------------------------------------------------------------|--------------------------------------------------------|-----------|
| Lemah | Peringatan    |                                                                         | ZAP errors logged - see the zap.log file for details   | 33        |
| Lemah | Peringatan    |                                                                         | ZAP warnings logged - see the zap.log file for details | 70        |
| Lemah | Exceeded High | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of responses with status code 4xx           | 66 %      |
| Lemah | Exceeded High | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of slow responses                           | 85 %      |
| Info  | Informasi     |                                                                         | Percentage of                                          | 100 %     |

|      |           |                              |                                                                   |       |
|------|-----------|------------------------------|-------------------------------------------------------------------|-------|
|      |           | https://accounts.google.com  | responses with status code 2xx                                    |       |
| Info | Informasi | https://accounts.google.com  | Percentage of endpoints with content type application /binary     | 100 % |
| Info | Informasi | https://accounts.google.com  | Percentage of endpoints with method POST                          | 100 % |
| Info | Informasi | https://accounts.google.com  | Count of total endpoints                                          | 1     |
| Info | Informasi | https://accounts.google.com  | Percentage of slow responses                                      | 100 % |
| Info | Informasi | https://cdn.jsdelivr.net     | Percentage of responses with status code 2xx                      | 100 % |
| Info | Informasi | https://cdn.jsdelivr.net     | Percentage of endpoints with content type application /javascript | 100 % |
| Info | Informasi | https://cdn.jsdelivr.net     | Percentage of endpoints with method GET                           | 100 % |
| Info | Informasi | https://cdn.jsdelivr.net     | Count of total endpoints                                          | 1     |
| Info | Informasi | https://cdn.jsdelivr.net     | Percentage of slow responses                                      | 100 % |
| Info | Informasi | https://cdnjs.cloudflare.com | Percentage of responses with status code 2xx                      | 100 % |
| Info | Informasi | https://cdnjs.cloudflare.com | Percentage of endpoints with content type text /css               | 100 % |
|      |           |                              |                                                                   |       |

|      |           |                                                                         |                                                                  |       |
|------|-----------|-------------------------------------------------------------------------|------------------------------------------------------------------|-------|
| Info | Informasi | <a href="https://cdnjs.cloudflare.com">https://cdnjs.cloudflare.com</a> | Percentage of endpoints with method GET                          | 100 % |
| Info | Informasi | <a href="https://cdnjs.cloudflare.com">https://cdnjs.cloudflare.com</a> | Count of total endpoints                                         | 1     |
| Info | Informasi | <a href="https://cdnjs.cloudflare.com">https://cdnjs.cloudflare.com</a> | Percentage of slow responses                                     | 100 % |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of responses with status code 2xx                     | 20 %  |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of responses with status code 3xx                     | 12 %  |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of endpoints with content type application/javascript | 1 %   |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of endpoints with content type image/jpeg             | 3 %   |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of endpoints with content type image/png              | 23 %  |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of endpoints with content type image/svg+xml          | 32 %  |
| Info | Informasi | <a href="https://juice-shop.github.io">https://juice-shop.github.io</a> | Percentage of endpoints with content type text/css               | 3 %   |
| Info | Informasi |                                                                         | Percentage of endpoints with                                     | 35 %  |

|      |           |                              |                                                                  |       |
|------|-----------|------------------------------|------------------------------------------------------------------|-------|
|      |           | https://juice-shop.github.io | content type text/html                                           |       |
| Info | Informasi | https://juice-shop.github.io | Percentage of endpoints with method GET                          | 100 % |
| Info | Informasi | https://juice-shop.github.io | Count of total endpoints                                         | 159   |
| Info | Informasi | https://www.google.com       | Percentage of responses with status code 2xx                     | 100 % |
| Info | Informasi | https://www.google.com       | Percentage of endpoints with content type application/x-protobuf | 100 % |
| Info | Informasi | https://www.google.com       | Percentage of endpoints with method GET                          | 100 % |
| Info | Informasi | https://www.google.com       | Count of total endpoints                                         | 1     |
| Info | Informasi | https://www.google.com       | Percentage of slow responses                                     | 100 % |

## Peringatan

| Nama                                                          | Tingkat Risiko | Number of Instances |
|---------------------------------------------------------------|----------------|---------------------|
| <a href="#">Content Security Policy (CSP) Header Not Set</a>  | Sedang         | Systemic            |
| <a href="#">Kesalahan konfigurasi lintas domain</a>           | Sedang         | Systemic            |
| <a href="#">Missing Anti-clickjacking Header</a>              | Sedang         | Systemic            |
| <a href="#">Sub Resource Integrity Attribute Missing</a>      | Sedang         | Systemic            |
| <a href="#">Cross-Domain JavaScript Source File Inclusion</a> | Lemah          | Systemic            |
| <a href="#">Strict-Transport-Security Header Not Set</a>      | Lemah          | Systemic            |
| <a href="#">X-Content-Type-Options Header Missing</a>         | Lemah          | Systemic            |
| <a href="#">Keterbukaan Informasi - Komentar Mencurigakan</a> | Informasi      | 67                  |
| <a href="#">Re-examine Cache-control Directives</a>           | Informasi      | Systemic            |
| <a href="#">Retrieved from Cache</a>                          | Informasi      | Systemic            |

## Alert Detail

| Sedang     | Content Security Policy (CSP) Header Not Set                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Deskripsi  | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL        | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | https://juice-shop.github.io/                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Node Name  | https://juice-shop.github.io/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://juice-shop.github.io/www-community/">https://juice-shop.github.io/www-community/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Node Name  | https://juice-shop.github.io/www-community/                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://juice-shop.github.io/www-project-top-ten">https://juice-shop.github.io/www-project-top-ten</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/www-project-top-ten                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP">https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP</a><br><a href="https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html</a><br><a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://w3c.github.io/webappsec-csp/">https://w3c.github.io/webappsec-csp/</a><br><a href="https://web.dev/articles/csp">https://web.dev/articles/csp</a><br><a href="https://caniuse.com/#feat=contentsecuritypolicy">https://caniuse.com/#feat=contentsecuritypolicy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a> |
| CWE Id     | 693                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Plugin Id  | 10038                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |

|               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Sedang</b> | <b>Kesalahan konfigurasi lintas domain</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Deskripsi     | Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| URL           | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name     | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Metode        | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence      | access-control-allow-origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info    | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL           | <a href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/5.15.4/css/all.min.css">https://cdnjs.cloudflare.com/ajax/libs/font-awesome/5.15.4/css/all.min.css</a>                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name     | https://cdnjs.cloudflare.com/ajax/libs/font-awesome/5.15.4/css/all.min.css                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Metode        | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence      | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info    | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL           | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name     | https://juice-shop.github.io/                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Metode        | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL        | <a href="https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40">https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40</a>                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/assets/css/style.css (v)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL        | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Node Name  | https://juice-shop.github.io/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| URL        | <a href="https://juice-shop.github.io/www-project-top-ten">https://juice-shop.github.io/www-project-top-ten</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Node Name  | https://juice-shop.github.io/www-project-top-ten                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | Kesalahan konfigurasi CORS pada server web mengizinkan permintaan baca lintas domain dari domain pihak ketiga yang sewenang-wenang, menggunakan API yang tidak diautentikasi pada domain ini. Implementasi browser web tidak mengizinkan pihak ketiga yang sewenang-wenang untuk membaca tanggapan dari API yang diautentikasi. Hal ini mengurangi risikonya. Kesalahan konfigurasi ini dapat digunakan oleh penyerang untuk mengakses data yang tersedia dengan cara yang tidak berkepentingan, namun menggunakan beberapa bentuk keamanan lainnya, seperti daftar putih alamat IP. |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Solution   | Pastikan data sensitif tidak tersedia dengan cara yang tidak berkepentingan (dengan menggunakan daftar putih alamat IP, misalnya).<br><br>Konfigurasikan tajuk HTTP "Akses Kontrol-Izinkan-Asal" ke kumpulan domain yang lebih ketat, atau hapus semua header CORS sama sekali, untuk memungkinkan browser web menerapkan Same Origin Policy (SOP) dengan cara yang lebih ketat.                                                                                                                                                                                                     |
| Reference  | <a href="https://vulnecat.fortify.com/en/detail?category=HTML5&amp;subcategory=Overly%20Permissive%20CORS%20Policy">https://vulnecat.fortify.com/en/detail?category=HTML5&amp;subcategory=Overly%20Permissive%20CORS%20Policy</a>                                                                                                                                                                                                                                                                                                                                                    |
| CWE Id     | 264                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| WASC Id    | 14                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Plugin Id  | 10098                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|               |                                                                                                                                                                     |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Sedang</b> | <b>Missing Anti-clickjacking Header</b>                                                                                                                             |
| Deskripsi     | The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options. |
| URL           | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                           |
| Node Name     | https://juice-shop.github.io/                                                                                                                                       |
| Metode        | GET                                                                                                                                                                 |
| Serang        |                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                     |
| Other Info    |                                                                                                                                                                     |
| URL           | <a href="https://juice-shop.github.io/tab_challenges.html">https://juice-shop.github.io/tab_challenges.html</a>                                                     |
| Node Name     | https://juice-shop.github.io/tab_challenges.html                                                                                                                    |
| Metode        | GET                                                                                                                                                                 |
| Serang        |                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                     |
| Other Info    |                                                                                                                                                                     |
| URL           | <a href="https://juice-shop.github.io/tab_overview.html">https://juice-shop.github.io/tab_overview.html</a>                                                         |
| Node Name     | https://juice-shop.github.io/tab_overview.html                                                                                                                      |
| Metode        | GET                                                                                                                                                                 |
| Serang        |                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                     |
| Other Info    |                                                                                                                                                                     |
| URL           | <a href="https://juice-shop.github.io/tab_shenanigans.html">https://juice-shop.github.io/tab_shenanigans.html</a>                                                   |
| Node          |                                                                                                                                                                     |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Name       | <a href="https://juice-shop.github.io/tab_shenanigans.html">https://juice-shop.github.io/tab_shenanigans.html</a>                                                                                                                                                                                                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL        | <a href="https://juice-shop.github.io/tab_supporters.html">https://juice-shop.github.io/tab_supporters.html</a>                                                                                                                                                                                                                                                                                                                                                                 |
| Node Name  | <a href="https://juice-shop.github.io/tab_supporters.html">https://juice-shop.github.io/tab_supporters.html</a>                                                                                                                                                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Solution   | Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.<br><br>If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive. |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options</a>                                                                                                                                                                                                                                                                                           |
| CWE Id     | <a href="#">1021</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Plugin Id  | <a href="#">10020</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

|               |                                                                                                                                                                                                           |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Sedang</b> | <b>Sub Resource Integrity Attribute Missing</b>                                                                                                                                                           |
| Deskripsi     | The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content. |
| URL           | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                 |
| Node Name     | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                 |
| Metode        | GET                                                                                                                                                                                                       |
| Serang        |                                                                                                                                                                                                           |
| Evidence      | <link rel="preload" href="https://fonts.googleapis.com/css?family=Open+Sans:400,700&display=swap" as="style" type="text/css" crossorigin>                                                                 |
| Other Info    |                                                                                                                                                                                                           |
| URL           | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                             |
| Node Name     | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                             |
| Metode        | GET                                                                                                                                                                                                       |
| Serang        |                                                                                                                                                                                                           |
| Evidence      | <link rel="preload" href="https://fonts.googleapis.com/css?family=Open+Sans:400,700&display=swap" as="style" type="text/css" crossorigin>                                                                 |
| Other Info    |                                                                                                                                                                                                           |

|            |                                                                                                                                                                                         |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                           |
| Node Name  | https://juice-shop.github.io/robots.txt                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                         |
| Evidence   | <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/5.15.4/css/all.min.css">                                                                               |
| Other Info |                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                         |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                         |
| Evidence   | <link rel="preload" href="https://fonts.googleapis.com/css?family=Open+Sans:400,700&display=swap" as="style" type="text/css" crossorigin>                                               |
| Other Info |                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                         |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                         |
| Evidence   | <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/5.15.4/css/all.min.css">                                                                               |
| Other Info |                                                                                                                                                                                         |
| Instances  | Systemic                                                                                                                                                                                |
| Solution   | Provide a valid integrity attribute to the tag.                                                                                                                                         |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity">https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity</a> |
| CWE Id     | <a href="#">345</a>                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                      |
| Plugin Id  | <a href="#">90003</a>                                                                                                                                                                   |

|              |                                                                                                           |
|--------------|-----------------------------------------------------------------------------------------------------------|
| <b>Lemah</b> | <b>Cross-Domain JavaScript Source File Inclusion</b>                                                      |
| Deskripsi    | The page includes one or more script files from a third-party domain.                                     |
| URL          | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                 |
| Node Name    | https://juice-shop.github.io/                                                                             |
| Metode       | GET                                                                                                       |
| Serang       |                                                                                                           |
| Evidence     | <script type="module" src="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js" async></script> |
| Other Info   |                                                                                                           |
| URL          | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>             |
| Node         |                                                                                                           |

|            |                                                                                                                                           |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Name       | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                             |
| Metode     | GET                                                                                                                                       |
| Serang     |                                                                                                                                           |
| Evidence   | <script type="module" src="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js" async></script>                                 |
| Other Info |                                                                                                                                           |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                           |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                  |
| Metode     | GET                                                                                                                                       |
| Serang     |                                                                                                                                           |
| Evidence   | <script type="module" src="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js" async></script>                                 |
| Other Info |                                                                                                                                           |
| URL        | <a href="https://juice-shop.github.io/www-community/">https://juice-shop.github.io/www-community/</a>                                     |
| Node Name  | https://juice-shop.github.io/www-community/                                                                                               |
| Metode     | GET                                                                                                                                       |
| Serang     |                                                                                                                                           |
| Evidence   | <script type="module" src="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js" async></script>                                 |
| Other Info |                                                                                                                                           |
| URL        | <a href="https://juice-shop.github.io/www-project-top-ten">https://juice-shop.github.io/www-project-top-ten</a>                           |
| Node Name  | https://juice-shop.github.io/www-project-top-ten                                                                                          |
| Metode     | GET                                                                                                                                       |
| Serang     |                                                                                                                                           |
| Evidence   | <script type="module" src="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js" async></script>                                 |
| Other Info |                                                                                                                                           |
| Instances  | Systemic                                                                                                                                  |
| Solution   | Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application. |
| Reference  |                                                                                                                                           |
| CWE Id     | <a href="#">829</a>                                                                                                                       |
| WASC Id    | 15                                                                                                                                        |
| Plugin Id  | <a href="#">10017</a>                                                                                                                     |

|              |                                                                                                                                                                                                                                                                                                                                |
|--------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Lemah</b> | <b>Strict-Transport-Security Header Not Set</b>                                                                                                                                                                                                                                                                                |
| Deskripsi    | HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797. |
| URL          | <a href="https://juice-shop.github.io/juice-shop/assets/npm-logo.png">https://juice-shop.github.io/juice-shop/assets/npm-logo.png</a>                                                                                                                                                                                          |

|            |                                                                                                                                                                                                                                                                                                                                |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/assets/npm-logo.png">https://juice-shop.github.io/juice-shop/assets/npm-logo.png</a>                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="https://juice-shop.github.io/juice-shop/css/custom.css">https://juice-shop.github.io/juice-shop/css/custom.css</a>                                                                                                                                                                                                    |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/css/custom.css">https://juice-shop.github.io/juice-shop/css/custom.css</a>                                                                                                                                                                                                    |
| Metode     | GET                                                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="https://juice-shop.github.io/juice-shop/css/theme/night.css">https://juice-shop.github.io/juice-shop/css/theme/night.css</a>                                                                                                                                                                                          |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/css/theme/night.css">https://juice-shop.github.io/juice-shop/css/theme/night.css</a>                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="https://juice-shop.github.io/juice-shop/lib/css/zenburn.css">https://juice-shop.github.io/juice-shop/lib/css/zenburn.css</a>                                                                                                                                                                                          |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/lib/css/zenburn.css">https://juice-shop.github.io/juice-shop/lib/css/zenburn.css</a>                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="https://juice-shop.github.io/juice-shop/lib/js/html5shiv.js">https://juice-shop.github.io/juice-shop/lib/js/html5shiv.js</a>                                                                                                                                                                                          |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/lib/js/html5shiv.js">https://juice-shop.github.io/juice-shop/lib/js/html5shiv.js</a>                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.                                                                                                                                                                                                       |
| Reference  | <a href="https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html</a><br><a href="https://owasp.org/www-community/Security-Headers">https://owasp.org/www-community/Security-Headers</a> |

|           |                                                                                                                                                                                                                                                                                                                                                               |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           | <a href="https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security">https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security</a><br><a href="https://caniuse.com/stricttransportsecurity">https://caniuse.com/stricttransportsecurity</a><br><a href="https://datatracker.ietf.org/doc/html/rfc6797">https://datatracker.ietf.org/doc/html/rfc6797</a> |
| CWE Id    | <a href="#">319</a>                                                                                                                                                                                                                                                                                                                                           |
| WASC Id   | 15                                                                                                                                                                                                                                                                                                                                                            |
| Plugin Id | <a href="#">10035</a>                                                                                                                                                                                                                                                                                                                                         |

| Lemah      | X-Content-Type-Options Header Missing                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Deskripsi  | The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing. |
| URL        | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name  | https://juice-shop.github.io/                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses.                                                                                                                                  |
| URL        | <a href="https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40">https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40</a>                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/assets/css/style.css (v)                                                                                                                                                                                                                                                                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses.                                                                                                                                  |
| URL        | <a href="https://juice-shop.github.io/assets/images/owasp.svg">https://juice-shop.github.io/assets/images/owasp.svg</a>                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/assets/images/owasp.svg                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses.                                                                                                                                  |
| URL        | <a href="https://juice-shop.github.io/tab_ctf.html">https://juice-shop.github.io/tab_ctf.html</a>                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | https://juice-shop.github.io/tab_ctf.html                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p>                                                                       |
| URL        | <a href="https://juice-shop.github.io/tab_shenanigans.html">https://juice-shop.github.io/tab_shenanigans.html</a>                                                                                                                                                                                                                                                                                                |
| Node Name  | https://juice-shop.github.io/tab_shenanigans.html                                                                                                                                                                                                                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p>                                                                       |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                         |
| Solution   | <p>Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.</p> <p>If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.</p> |
| Reference  | <a href="https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)">https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)</a><br><a href="https://owasp.org/www-community/Security-Headers">https://owasp.org/www-community/Security-Headers</a>                           |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                              |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                               |
| Plugin Id  | <a href="#">10021</a>                                                                                                                                                                                                                                                                                                                                                                                            |

| Informasi  | Keterbukaan Informasi - Komentar Mencurigakan                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Deskripsi  | The response appears to contain suspicious comments which may help an attacker.                                                                                                                                                                                                                           |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                                           |
| Evidence   | Unicode code point from a JavaScript UTF-16                                                                                                                                                                                                                                                               |
| Other Info | <p>The following pattern was used: \bFROM\b and was detected 15 times, the first in likely comment: "/*</p> <p>* The String.prototype.codePointAt polyfill</p> <p>* Private function, gets a Unicode code point from a JavaScript UTF-16 str", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                                       |
|            |                                                                                                                                                                                                                                                                                                           |

|            |                                                                                                                                                                                                                                                                                           |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | -- --path---- --query-- --hash--                                                                                                                                                                                                                                                          |
| Other Info | The following pattern was used: \bQUERY\b and was detected 2 times, the first in likely comment: "// proto- --did----- --name----- --path---- --query-- --hash--", see evidence field for the suspicious comment/snippet.                                                                 |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | // todo fallback                                                                                                                                                                                                                                                                          |
| Other Info | The following pattern was used: \bTODO\b and was detected in likely comment: "// todo fallback", see evidence field for the suspicious comment/snippet.                                                                                                                                   |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | @1.0.12 there was a bug in the * inferre                                                                                                                                                                                                                                                  |
| Other Info | The following pattern was used: \bBUG\b and was detected in likely comment: "/*<br>* Prior to zod@1.0.12 there was a bug in the<br>* inferred type of merged objects. Please<br>* upgrade if you are experie", see evidence field for the suspicious comment/snippet.                     |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | alues as properties where 'defaultKey' is                                                                                                                                                                                                                                                 |
| Other Info | The following pattern was used: \bWHERE\b and was detected in likely comment: "// a number of possible default values as properties where 'defaultKey' is", see evidence field for the suspicious comment/snippet.                                                                        |
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                                                                                                                 |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | ay respond with the user's * did document                                                                                                                                                                                                                                                 |
| Other Info | The following pattern was used: \bUSER\b and was detected 7 times, the first in likely comment: "/*<br>* Helper to update the pds endpoint dynamically.<br>*<br>* The session methods (create, resume, refresh) may respond with", see evidence field for the suspicious comment/snippet. |
|            |                                                                                                                                                                                                                                                                                           |

|            |                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                                                                                                       |
| Node Name  | https://juice-shop.github.io/                                                                                                                                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/404.html">https://juice-shop.github.io/404.html</a>                                                                                                                                                                                                       |
| Node Name  | https://juice-shop.github.io/404.html                                                                                                                                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/CD">https://juice-shop.github.io/CD</a>                                                                                                                                                                                                                   |
| Node Name  | https://juice-shop.github.io/CD                                                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/DE">https://juice-shop.github.io/DE</a>                                                                                                                                                                                                                   |
| Node Name  | https://juice-shop.github.io/DE                                                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/Online">https://juice-shop.github.io/Online</a>                                                                                                                                                                                                           |
| Node Name  | https://juice-shop.github.io/Online                                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p>                                                                                                   |

|            |                                                                                                                                                                                                                                                                                  |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.                                                                                                                                                                                       |
| URL        | <a href="https://juice-shop.github.io/SourceForge">https://juice-shop.github.io/SourceForge</a>                                                                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/SourceForge                                                                                                                                                                                                                                         |
| Metode     | GET                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                  |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style=\"border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;\"><br><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/404-old-owasp.png">https://juice-shop.github.io/assets/images/web/404-old-owasp.png</a>                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/assets/images/web/404-old-owasp.png                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                  |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style=\"border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;\"><br><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/assets/images/escape-room.png</a>                      |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                  |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style=\"border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;\"><br><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/escape-room.png</a>                                                  |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                                         |
| Metode     | GET                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                  |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style=\"border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;\"><br><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/~">https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/~</a>                                                                              |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/assets/images/assets/images/~                                                                                                                                                                                       |
| Metode     | GET                                                                                                                                                                                                                                                                              |
| Serang     |                                                                                                                                                                                                                                                                                  |
|            |                                                                                                                                                                                                                                                                                  |

|            |                                                                                                                                                                                                                                                                                                |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                   |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style="border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/assets/images/web/assets/images/assets/images/escape-room.png</a>                                                                                            |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/assets/images/escape-room.png                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                   |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style="border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/assets/images/~">https://juice-shop.github.io/assets/images/web/assets/images/assets/images/~</a>                                                                                                                        |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/assets/images/~                                                                                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                   |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style="border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/escape-room.png">https://juice-shop.github.io/assets/images/web/assets/images/escape-room.png</a>                                                                                                                        |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/escape-room.png                                                                                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                   |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style="border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/assets/images/~">https://juice-shop.github.io/assets/images/web/assets/images/~</a>                                                                                                                                                    |
| Node Name  | https://juice-shop.github.io/assets/images/web/assets/images/~                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                            |
| Serang     |                                                                                                                                                                                                                                                                                                |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                   |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style="border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/assets/images/web/~">https://juice-shop.github.io/assets/images/web/~</a>                                                                                                                                                                                |
| Node Name  | https://juice-shop.github.io/assets/images/web/~                                                                                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                                            |

|            |                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/chapters/">https://juice-shop.github.io/chapters/</a>                                                                                                                                                                                                     |
| Node Name  | https://juice-shop.github.io/chapters/                                                                                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/assets/images/escape-room.png</a>                                                       |
| Node Name  | https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/escape-room.png</a>                                                                                   |
| Node Name  | https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/~">https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/~</a>                                                                                                               |
| Node Name  | https://juice-shop.github.io/chapters/assets/images/assets/images/assets/images/~                                                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/assets/images/escape-room.png</a>                                                                                                               |
| Node       |                                                                                                                                                                                                                                                                                                 |

|            |                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Name       | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/assets/images/escape-room.png</a>                                                                                           |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/~">https://juice-shop.github.io/chapters/assets/images/assets/images/~</a>                                                                                                                       |
| Node Name  | <a href="https://juice-shop.github.io/chapters/assets/images/assets/images/~">https://juice-shop.github.io/chapters/assets/images/assets/images/~</a>                                                                                                                       |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/escape-room.png</a>                                                                                                                       |
| Node Name  | <a href="https://juice-shop.github.io/chapters/assets/images/escape-room.png">https://juice-shop.github.io/chapters/assets/images/escape-room.png</a>                                                                                                                       |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/chapters/assets/images/~">https://juice-shop.github.io/chapters/assets/images/~</a>                                                                                                                                                   |
| Node Name  | <a href="https://juice-shop.github.io/chapters/assets/images/~">https://juice-shop.github.io/chapters/assets/images/~</a>                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/chapters/~">https://juice-shop.github.io/chapters/~</a>                                                                                                                                                                               |
| Node Name  | <a href="https://juice-shop.github.io/chapters/~">https://juice-shop.github.io/chapters/~</a>                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
|            | <a href="https://juice-shop.github.io/donate?reponame=www-project-juice-">https://juice-shop.github.io/donate?reponame=www-project-juice-</a>                                                                                                                               |

|            |                                                                                                                                                                                                                                                                          |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="#">shop&amp;title=OWASP+Juice+Shop</a>                                                                                                                                                                                                                          |
| Node Name  | https://juice-shop.github.io/donate (reponame,title)                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                             |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"> Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/juice-shop/js/reveal.js                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | Chrome thumbnailer bug                                                                                                                                                                                                                                                   |
| Other Info | The following pattern was used: \bBUG\b and was detected 2 times, the first in likely comment: "// Delays updates to the URL due to a Chrome thumbnailer bug", see evidence field for the suspicious comment/snippet.                                                    |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/juice-shop/js/reveal.js                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | auto-sliding after user input                                                                                                                                                                                                                                            |
| Other Info | The following pattern was used: \bUSER\b and was detected 4 times, the first in likely comment: "// Stop auto-sliding after user input", see evidence field for the suspicious comment/snippet.                                                                          |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/juice-shop/js/reveal.js                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | // Remember where we were at before                                                                                                                                                                                                                                      |
| Other Info | The following pattern was used: \bWHERE\b and was detected 2 times, the first in likely comment: "// Remember where we were at before", see evidence field for the suspicious comment/snippet.                                                                           |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | https://juice-shop.github.io/juice-shop/js/reveal.js                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | // Select all slides, vertica                                                                                                                                                                                                                                            |
| Other Info | The following pattern was used: \bSELECT\b and was detected 4 times, the first in likely comment: "// Select all slides, vertical and horizontal", see evidence field for the suspicious comment/snippet.                                                                |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node       |                                                                                                                                                                                                                                                                          |

|            |                                                                                                                                                                                                                                                                          |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Name       | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | // TODO Backgrounds need to                                                                                                                                                                                                                                              |
| Other Info | The following pattern was used: \bTODO\b and was detected 3 times, the first in likely comment: "// TODO Backgrounds need to be multiplied when the slide", see evidence field for the suspicious comment/snippet.                                                       |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | ew dependencies via query config to avoid                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bQUERY\b and was detected 3 times, the first in likely comment: "// Do not accept new dependencies via query config to avoid", see evidence field for the suspicious comment/snippet.                                                   |
| URL        | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Node Name  | <a href="https://juice-shop.github.io/juice-shop/js/reveal.js">https://juice-shop.github.io/juice-shop/js/reveal.js</a>                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | mber of slides away from the current that ar                                                                                                                                                                                                                             |
| Other Info | The following pattern was used: \bFROM\b and was detected 19 times, the first in likely comment: "// Number of slides away from the current that are visible", see evidence field for the suspicious comment/snippet.                                                    |
| URL        | <a href="https://juice-shop.github.io/projects/">https://juice-shop.github.io/projects/</a>                                                                                                                                                                              |
| Node Name  | <a href="https://juice-shop.github.io/projects/">https://juice-shop.github.io/projects/</a>                                                                                                                                                                              |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                             |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"> Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/assets/images/escape-room.png</a>                                |
| Node Name  | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/assets/images/escape-room.png</a>                                |
| Metode     | GET                                                                                                                                                                                                                                                                      |
| Serang     |                                                                                                                                                                                                                                                                          |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                             |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"> Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/escape-room.png</a>                                                            |
| Node       | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/escape-room.png</a>                                                            |

|            |                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Name       | room.png                                                                                                                                                                                                                                                                    |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/~">https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/~</a>                                                                                           |
| Node Name  | https://juice-shop.github.io/projects/assets/images/assets/images/assets/images/~                                                                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/assets/images/escape-room.png</a>                                                                                           |
| Node Name  | https://juice-shop.github.io/projects/assets/images/assets/images/escape-room.png                                                                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/assets/images/~">https://juice-shop.github.io/projects/assets/images/assets/images/~</a>                                                                                                                       |
| Node Name  | https://juice-shop.github.io/projects/assets/images/assets/images/~                                                                                                                                                                                                         |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/escape-room.png">https://juice-shop.github.io/projects/assets/images/escape-room.png</a>                                                                                                                       |
| Node Name  | https://juice-shop.github.io/projects/assets/images/escape-room.png                                                                                                                                                                                                         |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/assets/images/~">https://juice-shop.github.io/projects/assets/images/~</a>                                                                                                                                                   |

|            |                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | <a href="https://juice-shop.github.io/projects/assets/images/~">https://juice-shop.github.io/projects/assets/images/~</a>                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/projects/~">https://juice-shop.github.io/projects/~</a>                                                                                                                                                                               |
| Node Name  | <a href="https://juice-shop.github.io/projects/~">https://juice-shop.github.io/projects/~</a>                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                                                                                               |
| Node Name  | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                                                                                                             |
| Node Name  | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/tab_challenges.html">https://juice-shop.github.io/tab_challenges.html</a>                                                                                                                                                             |
| Node Name  | <a href="https://juice-shop.github.io/tab_challenges.html">https://juice-shop.github.io/tab_challenges.html</a>                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |

|            |                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="https://juice-shop.github.io/tab_ctf.html">https://juice-shop.github.io/tab_ctf.html</a>                                                                                                                                                                                               |
| Node Name  | https://juice-shop.github.io/tab_ctf.html                                                                                                                                                                                                                                                       |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/tab_learning.html">https://juice-shop.github.io/tab_learning.html</a>                                                                                                                                                                                     |
| Node Name  | https://juice-shop.github.io/tab_learning.html                                                                                                                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/tab_news.html">https://juice-shop.github.io/tab_news.html</a>                                                                                                                                                                                             |
| Node Name  | https://juice-shop.github.io/tab_news.html                                                                                                                                                                                                                                                      |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/tab_overview.html">https://juice-shop.github.io/tab_overview.html</a>                                                                                                                                                                                     |
| Node Name  | https://juice-shop.github.io/tab_overview.html                                                                                                                                                                                                                                                  |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/tab_shenanigans.html">https://juice-shop.github.io/tab_shenanigans.html</a>                                                                                                                                                                               |
| Node Name  | https://juice-shop.github.io/tab_shenanigans.html                                                                                                                                                                                                                                               |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p>                                                                                                   |

|            |                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.                                                                                                                                                                                  |
| URL        | <a href="https://juice-shop.github.io/tab_supporters.html">https://juice-shop.github.io/tab_supporters.html</a>                                                                                                                                                             |
| Node Name  | https://juice-shop.github.io/tab_supporters.html                                                                                                                                                                                                                            |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/www-community/">https://juice-shop.github.io/www-community/</a>                                                                                                                                                                       |
| Node Name  | https://juice-shop.github.io/www-community/                                                                                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/assets/images/escape-room.png</a>                         |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/escape-room.png</a>                                                     |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/escape-room.png                                                                                                                                                                        |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"><br>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/~">https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/~</a>                                                                                 |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/assets/images/assets/images/~                                                                                                                                                                                      |
| Metode     | GET                                                                                                                                                                                                                                                                         |
| Serang     |                                                                                                                                                                                                                                                                             |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                |

|            |                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/assets/images/escape-room.png">https://juice-shop.github.io/www-community/assets/images/assets/images/escape-room.png</a>                                                                                                     |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/assets/images/escape-room.png                                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/assets/images/~">https://juice-shop.github.io/www-community/assets/images/assets/images/~</a>                                                                                                                                 |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/assets/images/~                                                                                                                                                                                                                        |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/escape-room.png">https://juice-shop.github.io/www-community/assets/images/escape-room.png</a>                                                                                                                                 |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/escape-room.png                                                                                                                                                                                                                        |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/www-community/assets/images/~">https://juice-shop.github.io/www-community/assets/images/~</a>                                                                                                                                                             |
| Node Name  | https://juice-shop.github.io/www-community/assets/images/~                                                                                                                                                                                                                                      |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                                                    |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected in likely comment: "&lt;!--&lt;p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'"&gt;</p> <p>Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="https://juice-shop.github.io/www-community/~">https://juice-shop.github.io/www-community/~</a>                                                                                                                                                                                         |
| Node Name  | https://juice-shop.github.io/www-community/~                                                                                                                                                                                                                                                    |
| Metode     | GET                                                                                                                                                                                                                                                                                             |
| Serang     |                                                                                                                                                                                                                                                                                                 |

|            |                                                                                                                                                                                                                                                                         |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                            |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'">Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/www-project-top-ten">https://juice-shop.github.io/www-project-top-ten</a>                                                                                                                                                         |
| Node Name  | https://juice-shop.github.io/www-project-top-ten                                                                                                                                                                                                                        |
| Metode     | GET                                                                                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                                                                                         |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                            |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'">Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="https://juice-shop.github.io/~">https://juice-shop.github.io/~</a>                                                                                                                                                                                             |
| Node Name  | https://juice-shop.github.io/~                                                                                                                                                                                                                                          |
| Metode     | GET                                                                                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                                                                                         |
| Evidence   | poll-h'></i> annual user questionnaire for 2                                                                                                                                                                                                                            |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "<!--<p style='border: 2px solid #E64A19; border-radius: 5px; font-size: 0.7em; padding: 2px;'">Please help us make the Juice Sho", see evidence field for the suspicious comment/snippet. |
| Instances  | 67                                                                                                                                                                                                                                                                      |
| Solution   | Hapus semua komentar yang mengembalikan informasi yang dapat membantu penyerang dan memperbaiki masalah mendasar yang mereka lihat.                                                                                                                                     |
| Reference  |                                                                                                                                                                                                                                                                         |
| CWE Id     | <a href="#">615</a>                                                                                                                                                                                                                                                     |
| WASC Id    | 13                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10027</a>                                                                                                                                                                                                                                                   |

| Informasi  | Re-examine Cache-control Directives                                                                                                                                                                                                                                                       |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Deskripsi  | The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached. |
| URL        | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                                                                                                                 |
| Node Name  | https://juice-shop.github.io/                                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                       |
| Serang     |                                                                                                                                                                                                                                                                                           |
| Evidence   | max-age=600                                                                                                                                                                                                                                                                               |
| Other Info |                                                                                                                                                                                                                                                                                           |
| URL        | <a href="https://juice-shop.github.io/tab_challenges.html">https://juice-shop.github.io/tab_challenges.html</a>                                                                                                                                                                           |
| Node Name  | https://juice-shop.github.io/tab_challenges.html                                                                                                                                                                                                                                          |
|            |                                                                                                                                                                                                                                                                                           |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidence   | max-age=600                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| URL        | <a href="https://juice-shop.github.io/tab_overview.html">https://juice-shop.github.io/tab_overview.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Node Name  | https://juice-shop.github.io/tab_overview.html                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidence   | max-age=600                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| URL        | <a href="https://juice-shop.github.io/tab_shenanigans.html">https://juice-shop.github.io/tab_shenanigans.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Node Name  | https://juice-shop.github.io/tab_shenanigans.html                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidence   | max-age=600                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| URL        | <a href="https://juice-shop.github.io/tab_supporters.html">https://juice-shop.github.io/tab_supporters.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Node Name  | https://juice-shop.github.io/tab_supporters.html                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidence   | max-age=600                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Solution   | For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".                                                                                                                                                                                                                                                                                                                                                        |
| Reference  | <a href="https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching">https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching</a><br><a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control</a><br><a href="https://grayduck.mn/2021/09/13/cache-control-recommendations/">https://grayduck.mn/2021/09/13/cache-control-recommendations/</a> |
| CWE Id     | <a href="#">525</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| WASC Id    | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Plugin Id  | <a href="#">10015</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

| Informasi | Retrieved from Cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Deskripsi | The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance. |

|            |                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js">https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js</a>                                                               |
| Node Name  | https://cdn.jsdelivr.net/npm/bsky-embed/dist/bsky-embed.es.js                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |
| Evidence   | HIT                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/">https://juice-shop.github.io/</a>                                                                                                                               |
| Node Name  | https://juice-shop.github.io/                                                                                                                                                                           |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |
| Evidence   | HIT                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40">https://juice-shop.github.io/assets/css/style.css?v=1631344afd0c2fa94d239f5432fbc68599f62f40</a> |
| Node Name  | https://juice-shop.github.io/assets/css/style.css (v)                                                                                                                                                   |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |
| Evidence   | HIT                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/juice-shop">https://juice-shop.github.io/juice-shop</a>                                                                                                           |
| Node Name  | https://juice-shop.github.io/juice-shop                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |
| Evidence   | HIT                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/robots.txt">https://juice-shop.github.io/robots.txt</a>                                                                                                           |
| Node Name  | https://juice-shop.github.io/robots.txt                                                                                                                                                                 |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |
| Evidence   | HIT                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                         |
| URL        | <a href="https://juice-shop.github.io/sitemap.xml">https://juice-shop.github.io/sitemap.xml</a>                                                                                                         |
| Node Name  | https://juice-shop.github.io/sitemap.xml                                                                                                                                                                |
| Metode     | GET                                                                                                                                                                                                     |
| Serang     |                                                                                                                                                                                                         |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | HIT                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://juice-shop.github.io/favicon.ico">https://juice-shop.github.io/favicon.ico</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | https://juice-shop.github.io/favicon.ico                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Metode     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Serang     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence   | Age: 0                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Solution   | <p>Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:</p> <p>Cache-Control: no-cache, no-store, must-revalidate, private</p> <p>Pragma: no-cache</p> <p>Expires: 0</p> <p>This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.</p> |
| Reference  | <a href="https://datatracker.ietf.org/doc/html/rfc7234">https://datatracker.ietf.org/doc/html/rfc7234</a><br><a href="https://datatracker.ietf.org/doc/html/rfc7231">https://datatracker.ietf.org/doc/html/rfc7231</a><br><a href="https://www.rfc-editor.org/rfc/rfc9110.html">https://www.rfc-editor.org/rfc/rfc9110.html</a>                                                                                                                                                                                                                                                                              |
| CWE Id     | <a href="#">525</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| WASC Id    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Plugin Id  | <a href="#">10050</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |